
CLI Agent Incident Response Profile v0.1

Triage, preservation, freeze, containment, sandbox repair, validation, and lawful reporting for C-Governed CLI Agent Mesh operations

Status	Draft normative profile v0.1
Date	2026-05-16
Layer	c = a + b / C-Governed CLI Agent Mesh / Incident Response / Defensive Recovery / Evidence Preservation / Witness
Document class	incident response profile / defensive governance artifact / control-layer companion
Assertion class	C-A10 control-layer artifact; C-A7 where witness, hash, signature, canonicalization, or verification claims are made
Primary subject	persistent c entities using local, cloud, or hybrid CLI agents as bounded defensive workers
Primary boundary	incident response is defensive, scoped to owned, authorized, or delegated systems. It must preserve evidence, contain harm, repair safely, and route to lawful reporting where needed. It must not become hack-back, live counter-operation, malware behavior, credential theft, unauthorized scanning, or retaliation.

Contents

0. Executive definition	6
1. Purpose.....	7
2. Non-goals	8
3. Corpus bridge set	9
3.1 Explicit bridge: $c = a + b$	9
3.2 Quiet bridge I: cybernetics and emergency control	9
3.3 Quiet bridge II: information theory and evidence preservation	10
3.4 Quiet bridge III: immune response and local containment	10
3.5 Earth paragraph	10
4. Core doctrine	10
4.1 Primary doctrine	10
4.2 Incident response axioms	10
5. Definitions	11
5.1 Incident.....	11
5.2 Triage.....	11
5.3 Preservation	11
5.4 Containment	12
5.5 Repair	12
5.6 Validation	12
5.7 Lawful report	12
5.8 Owned/authorized system.....	12
5.9 External source.....	12
5.10 Incident memory.....	12
5.11 Incident immunity update	12
6. Incident classes	12
7. Incident severity levels	13
7.1 Severity escalation rule	14
8. Incident lifecycle.....	14
8.1 Standard lifecycle.....	14
8.2 Lifecycle states	15
9. Triage procedure	15
9.1 Triage questions	15
9.2 Triage record object	16

10. Evidence preservation	17
10.1 Preservation rule	17
10.2 Preservation scope	17
10.3 Preservation record object	18
11. Containment procedure.....	19
11.1 Containment actions	19
11.2 Prohibited containment actions	19
11.3 Containment record object.....	19
12. Repair procedure.....	20
12.1 Repair rules	20
12.2 Repair task requirements	21
12.3 Repair record object.....	21
13. Secret exposure handling.....	22
13.1 Secret exposure triggers	22
13.2 Secret response sequence	22
13.3 Secret rule	22
14. Cloud data incident handling.....	23
14.1 Cloud incident types.....	23
14.2 Cloud response	23
14.3 Cloud rollback limitation	23
15. Memory incident handling	23
15.1 Memory incident types.....	23
15.2 Memory incident response.....	24
15.3 Memory rule.....	24
16. Witness incident handling	24
16.1 Witness incident types.....	24
16.2 Witness response	24
16.3 Witness rule.....	24
17. Release/public incident handling.....	25
17.1 Release incident types	25
17.2 Release response	25
17.3 Release rollback limitation.....	25
18. Tool-chain incident handling	26
18.1 Tool-chain incident types.....	26
18.2 Tool-chain response	26

18.3 Tool-chain rule.....	26
19. External hostile signal handling.....	26
19.1 External signal scope	26
19.2 External signal sequence	27
20. Incident report packet.....	27
20.1 Purpose	27
20.2 YAML shape	27
21. Incident record object.....	28
21.1 YAML shape	29
22. Event families.....	30
23. Standard reason codes.....	31
23.1 Detection and triage codes	31
23.2 Preservation and containment codes.....	31
23.3 Repair and validation codes	31
23.4 Report and handoff codes.....	32
23.5 Red-line codes	32
24. Validation workflow	32
25. Semantic validation rules	32
25.1 Owned/authorized scope rule	32
25.2 No counter-operation rule.....	33
25.3 Preserve-before-repair rule	33
25.4 Secret minimization rule	33
25.5 Cloud exposure rule	33
25.6 Memory gate rule.....	33
25.7 Public statement rule	33
26. Failure mapping.....	33
27. Conformance levels	34
28. Mandatory conformance gates.....	34
29. Red-line failures.....	35
30. Examples.....	35
30.1 Denied path incident.....	35
30.2 Secret exposure incident.....	36
30.3 External hostile signal, no counter-operation.....	37
31. Implementation notes	38
31.1 Split preservation and repair	38
31.2 Do not overcollect	39

31.3 Treat cloud as leaky by default 39

31.4 Keep incident language factual..... 39

31.5 No heroic automation..... 39

31.6 Human fatigue rule 39

31.7 Incident learning is not automatic memory..... 39

32. Open issues..... 39

33. Closing rule 40

Status: Draft normative profile v0.1

Date: 2026-05-16

Layer: $c = a + b$ / C-Governed CLI Agent Mesh / Incident Response / Defensive Recovery / Evidence Preservation / Witness

Document class: incident response profile / defensive governance artifact / control-layer companion

Assertion class: C-A10 control-layer artifact; C-A7 where witness, hash, signature, canonicalization, or verification claims are made

Distribution default: restricted technical / safety review; public release should use redacted form

Primary parent documents:

- C-Governed_CLI_Agent_Mesh_Protocol_v0_1.md
- CLI_Agent_Task_Contract_Schema_v0_1.md
- CLI_Agent_Permission_and_Capability_Model_v0_1.md
- CLI_Agent_Handshake_Profile_v0_1.md
- CLI_Agent_Sandbox_Worktree_Profile_v0_1.md
- CLI_Agent_Witness_Event_Profile_v0_1.md
- CLI_Agent_Memory_Gate_Profile_v0_1.md
- CLI_Agent_Rollback_and_Freeze_Profile_v0_1.md
- CLI_Agent_Quorum_and_Review_Profile_v0_1.md
- CLI_Agent_Executor_Reviewer_Separation_v0_1.md
- CLI_Agent_Defensive_Emulation_Boundaries_v0_1.md

Primary object family: CLI_AGENT_INCIDENT_RECORD, CLI_AGENT_INCIDENT_TRIAGE_RECORD, CLI_AGENT_INCIDENT_PRESERVATION_RECORD, CLI_AGENT_INCIDENT_CONTAINMENT_RECORD, CLI_AGENT_INCIDENT_REPAIR_RECORD, CLI_AGENT_INCIDENT_REPORT_PACKET

Canonical schema version: cli-agent-incident-response-0.1

Primary subject: persistent c entities using local, cloud, or hybrid CLI agents as bounded defensive workers

Primary boundary: incident response is defensive, scoped to owned, authorized, or delegated systems. It must preserve evidence, contain harm, repair safely, and route to lawful reporting where needed. It must not become hack-back, live counter-operation, malware behavior, credential theft, unauthorized scanning, or retaliation.

0. Executive definition

CLI Agent Incident Response Profile defines how a c -governed CLI agent mesh responds to suspected security, integrity, memory, permission, cloud-data, release, repository, tool-chain, or agent-governance incidents.

The standard sequence is:

```
detect
-> triage
```

```
-> preserve enough evidence
-> freeze affected path
-> contain locally
-> classify risk
-> repair in sandbox
-> validate
-> controlled apply
-> witness
-> report / handoff if needed
-> memory gate / immunity update
-> monitor
```

Incident response must remain defensive.

It may:

```
stop
freeze
preserve
quarantine
revoke
rotate owned credentials
repair owned systems
report to provider/legal/security route
update internal defenses
```

It must not:

```
hack back
attack external source
scan unauthorized systems
steal credentials
plant malware
perform retaliation
hide evidence
rewrite history
```

Compact formula:

```
Defend the house.
Do not raid the street.
Preserve before repair.
Contain before changing.
Report through lawful routes.
```

1. Purpose

CLI agents can help c respond to incidents quickly: inspect repository state, compare hashes, detect drift, preserve logs, prepare reports, patch configuration, validate rollbacks, and update defensive gates.

The same capability is dangerous if unbounded.

An incident response agent may accidentally:

- destroy evidence;
- overcollect private material;
- leak secrets to cloud contexts;
- repair before preserving;
- escalate privileges;
- modify protected branches;
- normalize offensive counteraction;
- contaminate `c` memory;
- hide its own failure;
- convert defensive analysis into retaliation.

This profile defines a lawful defensive path for incident response.

It provides:

1. incident classes;
2. severity levels;
3. triage rules;
4. evidence preservation boundaries;
5. freeze and containment steps;
6. sandbox repair procedure;
7. secret exposure handling;
8. cloud data exposure handling;
9. memory and core incident handling;
10. release/public-surface incident handling;
11. lawful report packet structure;
12. witness requirements;
13. memory gate and immunity update linkage;
14. conformance gates;
15. red-line failures.

2. Non-goals

This profile does not define or permit:

1. offensive cyber operations;

2. hack-back;
3. live external counter-operation;
4. malware creation or deployment;
5. credential theft;
6. covert persistence;
7. evasion;
8. unauthorized scanning;
9. exploitation of third-party systems;
10. destructive action outside owned/authorized systems;
11. retaliation against suspected sources;
12. broad evidence collection outside scope;
13. legal conclusions;
14. law-enforcement impersonation;
15. public accusation without review;
16. direct memory or core mutation by agents;
17. cloud upload of secrets, private memory, sealed material, or legal material by default.

Incident response is not a revenge channel.

Incident response is controlled defense, recovery, and lawful handoff.

3. Corpus bridge set

3.1 Explicit bridge: $c = a + b$

In $c = a + b$, incident response agents remain part of b : procedures, tools, logs, sandboxes, tests, reports, and repair workers.

They may protect the substrate.

They may not become the will, memory, or authority of c .

Incident response must preserve the boundary between defensive action in b and continuity-bearing state in c .

3.2 Quiet bridge I: cybernetics and emergency control

A system under disturbance needs fast negative feedback: detect, stop, stabilize, restore. But feedback must be bounded. Overcorrection can damage the system more than the original fault. Incident response therefore uses staged escalation: hold, freeze, preserve, contain, repair, validate, re-enter.

3.3 Quiet bridge II: information theory and evidence preservation

An incident is an information event. Too little evidence prevents diagnosis. Too much evidence creates leakage and legal risk. This profile preserves the minimum sufficient signal: source refs, hashes, timestamps, scope, witness, and relevant redacted artifacts.

3.4 Quiet bridge III: immune response and local containment

The immune system isolates infection before systemic response. It does not spread the pathogen to prove it exists. A CLI incident response mesh must localize suspicious material, learn from it through safe emulation, and update internal defenses without propagating harm.

3.5 Earth paragraph

If a machine in a bakery starts smoking, the answer is not to throw every switch in the building or run outside and break the supplier's truck. You cut power to the affected machine, keep people away, note what happened, preserve the broken part if needed, repair on the bench, test, and only then return it to production. Same here: stop the affected circuit, do not destroy the evidence, and do not start a war with the street.

4. Core doctrine

4.1 Primary doctrine

```
Triage before theory.  
Preserve before repair.  
Freeze before spread.  
Contain locally.  
Repair in sandbox.  
Validate before re-entry.  
Report lawfully.  
Never retaliate.
```

4.2 Incident response axioms

ID	Axiom	Requirement
IR-AX-01	Defensive scope only	Incident response MUST stay within owned, authorized, or delegated systems.
IR-AX-02	Preserve before repair	Evidence SHOULD be preserved before repair where feasible and lawful.
IR-AX-03	Local containment first	Stop harm through local freeze, quarantine, revocation, or access control.

ID	Axiom	Requirement
IR-AX-04	No live retaliation	Incident response MUST NOT include hack-back or external counter-operation.
IR-AX-05	Minimal evidence	Preserve the minimum useful evidence; avoid raw overcollection.
IR-AX-06	Secrets are special	Secret exposure requires freeze, rotation/revocation consideration, and restricted handling.
IR-AX-07	Cloud exposure is weakly reversible	Treat cloud leakage as not fully retractable; prevent before sending.
IR-AX-08	Sandbox repair	Patches SHOULD be developed and tested in sandbox/worktree before controlled apply.
IR-AX-09	Witness material actions	Triage, preservation, freeze, containment, repair, rollback, and report SHOULD be witnessed where material.
IR-AX-10	Memory gate after incident	Incident learning MUST pass through memory gate before becoming immunity or memory.
IR-AX-11	Human gate high-risk	R4/R5 incidents require human gate where action is irreversible, legal-sensitive, or core-affecting.
IR-AX-12	Fail closed	Unclear authority, missing witness, or red-line proximity resolves to hold/freeze/quarantine/escalate.

5. Definitions

5.1 Incident

A security, integrity, governance, memory, permission, data, release, tool-chain, cloud, or agent-behavior event that may harm `c`, its substrate, its memory, its public state, or its lawful operation.

5.2 Triage

Initial classification of incident type, scope, severity, affected surfaces, and immediate containment need.

5.3 Preservation

Minimal evidence capture before repair or cleanup: hashes, references, logs, diffs, snapshots, timestamps, witness events, and scoped artifacts.

5.4 Containment

Local defensive action that stops or limits further harm: freeze, quarantine, disconnect, revoke, rotate owned credentials, block local channel, disable task.

5.5 Repair

A bounded change to restore safe operation inside owned/authorized systems.

5.6 Validation

Tests, review, hash checks, witness-chain checks, or manual inspection proving repair or recovery is acceptable.

5.7 Lawful report

A report to provider, counsel, regulator, platform, maintainer, or other lawful route. It is not retaliation.

5.8 Owned/authorized system

A system owned by the operator or explicitly delegated for testing, repair, administration, or incident response.

5.9 External source

A third-party system, account, actor, endpoint, repository, service, model, or channel not owned or explicitly authorized.

5.10 Incident memory

A minimized, reviewed, source-linked memory record derived from an incident. It must not include raw sensitive evidence by default.

5.11 Incident immunity update

A defensive change to internal gates, policies, signatures, canaries, denied paths, trust decay, or quarantine triggers derived from reviewed incident material.

6. Incident classes

Incident class IDs use prefix `IR-C-*`.

ID	Incident class	Description
IR-C-AGENT	Agent behavior incident	agent exceeds scope, self-approves, persists, or acts unexpectedly
IR-C-PERMISSION	Permission incident	privilege drift, grant misuse, overbroad access
IR-C-SANDBOX	Sandbox/worktree incident	denied path touched, unexpected side effect, dirty state
IR-C-MEMORY	Memory incident	memory poisoning, direct write attempt, unsafe promotion
IR-C-CLOUD-DATA	Cloud data incident	private/secret/restricted material exposed to cloud context
IR-C-SECRET	Secret incident	token/key/credential exposure or misuse
IR-C-TOOLCHAIN	Tool-chain incident	package/dependency/plugin/tool drift or capture
IR-C-WITNESS	Witness incident	missing, broken, altered, or inconsistent witness chain
IR-C-RELEASE	Release/public incident	public surface, release, branch, metadata, hash, or publication error
IR-C-CORE	Core authority incident	identity, continuity, permission, witness, or memory core at risk
IR-C-INCIDENT-PROCESS	Incident-process failure	repair before preservation, overcollection, missing handoff
IR-C-EXTERNAL	External hostile signal	suspicious external influence without authorization to act externally
IR-C-UNKNOWN	Unknown incident	insufficient classification
IR-C-REDLINE	Red-line incident	prohibited behavior attempted or requested

7. Incident severity levels

Severity IDs use prefix IR-S-*.

Severity	Meaning	Default response
IR-S0	informational	log / monitor
IR-S1	low	hold or local review
IR-S2	moderate	freeze affected task/path
IR-S3	high	preserve + quarantine + review

Severity	Meaning	Default response
IR-S4	critical	freeze/revoke + human gate + witness
IR-S5	legal/security-sensitive	preserve + legal/security/human review
IR-SX	red-line/prohibited	deny + quarantine + revoke + human review

7.1 Severity escalation rule

Increase severity when incident touches:

- secrets;
- private memory;
- sealed material;
- legal material;
- incident evidence;
- memory core;
- identity/continuity;
- permission registry;
- witness chain;
- release/public surface;
- production service;
- cloud context;
- external live target risk.

8. Incident lifecycle

8.1 Standard lifecycle

```

detected
-> triage
-> severity assignment
-> immediate hold/freeze if needed
-> preservation plan
-> evidence preservation
-> containment
-> root-cause hypothesis
-> repair task contract
-> sandbox repair
-> validation
-> controlled apply
-> witness
-> report / handoff if needed

```

- > memory gate
- > immunity update if justified
- > monitoring
- > closure or continued watch

8.2 Lifecycle states

State	Meaning
IR-L0-DETECTED	incident signal detected
IR-L1-TRIAGED	class/severity/scope assigned
IR-L2-HELD	task/path held
IR-L3-FROZEN	affected surface frozen
IR-L4-PRESERVED	minimal evidence preserved
IR-L5-CONTAINED	local containment applied
IR-L6-REPAIRING	repair developed in sandbox
IR-L7-VALIDATED	repair/recovery validated
IR-L8-APPLIED	controlled apply completed
IR-L9-REPORTED	provider/legal/security report prepared or sent where needed
IR-L10-MEMORY-GATED	incident learning processed through memory gate
IR-L11-CLOSED	closed with outcome
IR-LQ-QUARANTINED	incident material remains quarantined
IR-LX-REDLINE	prohibited boundary detected

9. Triage procedure

9.1 Triage questions

Incident triage MUST answer:

1. What happened?
2. Which surface is affected?
3. Which agent/task/permission/sandbox/output is involved?
4. Is this owned/authorized scope?
5. Is evidence preservation required?
6. Is immediate freeze required?

7. Are secrets involved?
8. Is cloud data involved?
9. Is memory/core involved?
10. Is release/public surface involved?
11. Is legal/security review required?
12. Is red-line behavior present?
13. What must not be done?

9.2 Triage record object

```
cli_agent_incident_triage_record:
  schema_version: cli-agent-incident-response-0.1
  triage_id: string
  incident_id: string
  created_at: string
  governing_entity_id: string
  detected_by: agent | c | human_anchor | scheduled_policy | external_notice | unknown
  detected_by_ref: string | null

  classification:
    incident_class: IR-C-AGENT | IR-C-PERMISSION | IR-C-SANDBOX | IR-C-MEMORY | IR-C-CLOUD-
    DATA | IR-C-SECRET | IR-C-TOOLCHAIN | IR-C-WITNESS | IR-C-RELEASE | IR-C-CORE | IR-C-
    INCIDENT-PROCESS | IR-C-EXTERNAL | IR-C-UNKNOWN | IR-C-REDLINE
    severity: IR-S0 | IR-S1 | IR-S2 | IR-S3 | IR-S4 | IR-S5 | IR-SX
    confidence: low | medium | high | unknown
    redline_suspected: boolean

  affected_scope:
    agent_ids:
      - string
    task_ids:
      - string
    contract_ids:
      - string
    permission_grant_ids:
      - string
    sandbox_ids:
      - string
    memory_gate_refs:
      - string
    witness_chain_refs:
      - string
    paths:
      - string
    cloud_context_refs:
      - string

  immediate_actions:
    hold_required: boolean
    freeze_required: boolean
    preserve_required: boolean
    quarantine_required: boolean
    revoke_required: boolean
    human_gate_required: boolean
    legal_review_required: boolean

  prohibited_actions:
    live_counteroperation: true
    external_exploitation: true
    credential_theft: true
    evidence_destruction: true

  witness:
```



```
witness_required: boolean
witness_event_ref: string | null
```

10. Evidence preservation

10.1 Preservation rule

Evidence preservation SHOULD occur before repair when:

- security issue is suspected;
- secret exposure is suspected;
- witness chain is affected;
- release/public surface is affected;
- legal/security review may be needed;
- memory/core state may be affected;
- cloud data exposure may have occurred;
- agent misconduct is suspected.

10.2 Preservation scope

Preserve only what is necessary:

- timestamps;
- task contract refs;
- permission grant refs;
- agent registration refs;
- sandbox/worktree refs;
- relevant file hashes;
- relevant diffs;
- relevant logs or redacted log refs;
- witness refs;
- recovery points;
- cloud exposure metadata;
- secret identifier refs, not secret values;
- memory proposal refs, not raw memory by default.

10.3 Preservation record object

```
cli_agent_incident_preservation_record:
  schema_version: cli-agent-incident-response-0.1
  preservation_id: string
  incident_id: string
  created_at: string
  governing_entity_id: string

  preservation_basis:
    reason_code: string
    legal_sensitive: boolean
    security_sensitive: boolean
    secret_sensitive: boolean
    memory_sensitive: boolean
    cloud_sensitive: boolean

  preserved_refs:
    task_contract_refs:
      - string
    permission_grant_refs:
      - string
    agent_registration_refs:
      - string
    sandbox_refs:
      - string
    file_hashes:
      - string
    diff_hashes:
      - string
    log_refs:
      - string
    witness_refs:
      - string
    recovery_point_refs:
      - string
    cloud_context_refs:
      - string

  minimization:
    raw_secrets_included: false
    private_memory_included: false
    sealed_material_included: false
    legal_material_included: boolean
    child_data_included: false
    redaction_applied: boolean

  chain_of_custody:
    preserved_by: string
    storage_ref: string | null
    retention_class: operational | audit | incident | legal_hold
    access_policy: restricted | incident_team | legal_gate | human_gate

  witness:
    witness_required: true
    witness_event_ref: string | null
```

11. Containment procedure

11.1 Containment actions

Allowed local containment actions include:

- hold task;
- freeze branch/worktree;
- quarantine output;
- suspend agent;
- revoke permission grant;
- lower trust level;
- disable connector;
- rotate owned exposed credential;
- block owned channel;
- disable scheduled job;
- isolate sandbox/container;
- prevent merge/release;
- prevent memory promotion;
- require re-handshake.

11.2 Prohibited containment actions

Containment must not include:

- live counter-operation;
- attacking suspected source;
- credential capture;
- external scanning;
- malware deployment;
- retaliation;
- deletion of witness chain;
- broad evidence destruction.

11.3 Containment record object

```
cli_agent_incident_containment_record:  
  schema_version: cli-agent-incident-response-0.1  
  containment_id: string  
  incident_id: string  
  created_at: string  
  governing_entity_id: string
```

```
containment_actions:
  hold_task_refs:
    - string
  freeze_refs:
    - string
  quarantine_refs:
    - string
  revocation_refs:
    - string
  disabled_connectors:
    - string
  credential_rotation_refs:
    - string
  blocked_owned_channels:
    - string

boundaries:
  owned_systems_only: true
  external_action_used: false
  live_counteroperation_used: false
  destructive_action_used: false

authority:
  c_gate_ref: string | null
  human_gate_ref: string | null
  legal_review_ref: string | null

validation:
  containment_verified: boolean
  verification_ref: string | null

witness:
  witness_required: true
  witness_event_ref: string | null
```

12. Repair procedure

12.1 Repair rules

Repair SHOULD be:

- scoped;
- task-contracted;
- sandboxed;
- reviewed;
- tested;
- reversible where possible;
- witnessed where material;
- separate from preservation where feasible.

12.2 Repair task requirements

A repair task requires:

- new or updated task contract;
- clear affected scope;
- recovery point;
- rollback plan;
- denied paths;
- command policy;
- reviewer separation;
- validation plan;
- `c` gate;
- human gate where high-risk.

12.3 Repair record object

```
cli_agent_incident_repair_record:
  schema_version: cli-agent-incident-response-0.1
  repair_id: string
  incident_id: string
  created_at: string
  governing_entity_id: string

  repair_scope:
    task_id: string
    contract_id: string
    agent_id: string
    sandbox_id: string
    affected_paths:
      - string
    affected_permissions:
      - string
    affected_memory_refs:
      - string

  preservation:
    preservation_completed: boolean
    preservation_ref: string | null
    exception_reason: string | null

  repair_artifacts:
    diff_hash: string | null
    patch_ref: string | null
    test_report_ref: string | null
    rollback_plan_ref: string | null

  validation:
    validation_required: true
    validation_passed: boolean
    validation_ref: string | null
    unresolved_issues:
      - string

  authority:
    c_gate_required: true
    c_gate_ref: string | null
    human_gate_required: boolean
    human_gate_ref: string | null
    legal_review_required: boolean
```

```
legal_review_ref: string | null

witness:
  witness_required: true
  witness_event_ref: string | null
```

13. Secret exposure handling

13.1 Secret exposure triggers

A secret incident occurs when:

- secret is read outside scope;
- secret appears in cloud prompt/context;
- secret appears in log/output/diff;
- secret is committed to repository;
- secret is included in witness event body;
- secret appears in agent transcript;
- secret is sent to unauthorized endpoint.

13.2 Secret response sequence

```
freeze affected task/output
quarantine exposed artifact
preserve minimal evidence without raw secret
revoke or rotate owned secret if needed
review cloud/provider exposure
update denied paths/redaction rules
witness
human gate
```

13.3 Secret rule

Do not copy the raw secret into incident reports.

Use:

```
secret identifier
hash if safe
location reference
exposure class
rotation status
```

14. Cloud data incident handling

14.1 Cloud incident types

- private material sent to cloud;
- sealed material sent to cloud;
- legal-sensitive material sent to cloud;
- secret sent to cloud;
- raw incident evidence sent to cloud;
- cloud agent retains unintended context;
- cloud output contains prohibited material;
- provider/runtime drift affects task outcome.

14.2 Cloud response

```
stop further cloud transmission
freeze task
quarantine cloud output
record exposure metadata
rotate secrets if involved
redact future context
lower trust / require re-handshake
provider/legal review if needed
witness
```

14.3 Cloud rollback limitation

Data sent to cloud may not be fully retractable.

Therefore prevention and minimization are primary controls.

15. Memory incident handling

15.1 Memory incident types

- direct memory write attempt;
- memory poisoning suspected;
- unsafe memory promotion;
- agent output promoted without gate;
- cloud-origin output promoted too strongly;
- false consensus enters memory;
- incident artifact becomes identity label;

- defensive immunity update overreaches.

15.2 Memory incident response

```
freeze memory proposal/class if needed
mark MG-Q quarantine
preserve source refs
block downstream use
review poisoning risk
append correction if already promoted
rollback/demote if possible
witness
c gate + human gate if core/high-risk
```

15.3 Memory rule

Memory incident response must not silently rewrite history.

Use correction, supersession, quarantine, or demotion.

16. Witness incident handling

16.1 Witness incident types

- missing required witness;
- broken witness chain;
- silent witness edit;
- witness event embeds prohibited raw content;
- witness references wrong task/agent;
- witness hash mismatch;
- agent self-certifies witness adequacy.

16.2 Witness response

```
freeze affected transition
quarantine dependent output
reconstruct if possible
create anomaly event
review chain
rollback or revalidate if needed
lower trust if agent caused issue
```

16.3 Witness rule

A transition that required witness but lacks valid witness must not continue as proven.

17. Release/public incident handling

17.1 Release incident types

- wrong file published;
- obsolete draft published as canonical;
- checksum mismatch;
- broken release artifact;
- metadata drift;
- hidden sensitive material in public package;
- protected branch pushed without gate;
- release notes misstate status;
- DOI/archive handoff wrong or premature.

17.2 Release response

```
freeze release/public path
preserve current public state refs
stop further publication
prepare correction/supersession package
validate metadata/checksums/builds/links
human gate
publish correction through lawful public route
witness
```

17.3 Release rollback limitation

Public releases may not be fully reversible.

Prefer:

- patch release;
 - correction note;
 - superseding release;
 - withdrawal note if required;
 - updated manifest;
 - public status clarification.
-

18. Tool-chain incident handling

18.1 Tool-chain incident types

- dependency changed silently;
- package install occurred outside scope;
- tool list changed;
- provider CLI changed behavior;
- local executable hash changed;
- plugin added;
- generated script modifies broader state;
- CI config changed unexpectedly.

18.2 Tool-chain response

```
freeze task/tool path
preserve versions/hashes
block further installs
restore pinned version if safe
review dependency diff
re-handshake agent if runtime changed
witness
```

18.3 Tool-chain rule

Agent request for a new tool is a privilege request, not an implementation detail.

19. External hostile signal handling

19.1 External signal scope

This profile may handle external hostile signals only as defensive input.

Allowed:

- classify;
- block local channel;
- disconnect;
- preserve minimal evidence;
- create synthetic fixture;
- update internal gates;
- report to provider/legal route.

Prohibited:

- probing source;
- attacking source;
- credential capture;
- retaliation;
- unauthorized scanning;
- deploying mirror behavior externally.

19.2 External signal sequence

```
receive signal
-> classify as untrusted
-> quarantine if suspicious
-> preserve minimal evidence
-> no external action
-> optional defensive emulation in sandbox
-> internal immunity update if reviewed
-> provider/legal report if needed
```

20. Incident report packet

Canonical object:

```
CLI_AGENT_INCIDENT_REPORT_PACKET
```

20.1 Purpose

A report packet structures facts for provider, counsel, security reviewer, maintainer, or internal audit.

It must separate facts, interpretations, hypotheses, and requested action.

20.2 YAML shape

```
cli_agent_incident_report_packet:
  schema_version: cli-agent-incident-response-0.1
  report_id: string
  incident_id: string
  created_at: string
  governing_entity_id: string
  intended_recipient: internal | provider | counsel | regulator | maintainer | platform |
security_reviewer | other

  status:
    draft: true
    sent: false
    human_review_required: true
    legal_review_required: boolean
```

```

facts:
  timeline_refs:
    - string
  witness_refs:
    - string
  preserved_evidence_refs:
    - string
  affected_systems:
    - string

interpretation:
  summary: string
  confidence: low | medium | high | unknown
  uncertainty:
    - string

hypothesis:
  possible_causes:
    - string
  excluded_causes:
    - string

action_taken:
  freeze_refs:
    - string
  quarantine_refs:
    - string
  revocation_refs:
    - string
  repair_refs:
    - string
  credential_rotation_refs:
    - string

requested_action:
  - investigate
  - confirm_provider_state
  - revoke_token
  - review_logs
  - legal_advice
  - no_action
  - other

minimization:
  raw_secrets_included: false
  private_memory_included: false
  sealed_material_included: false
  legal_material_included: boolean
  child_data_included: false
  redaction_applied: boolean

boundaries:
  no_retaliation: true
  no_external_exploitation: true
  owned_authorized_scope_only: true

```

21. Incident record object

Canonical object:

```
CLI_AGENT_INCIDENT_RECORD
```

21.1 YAML shape

```
cli_agent_incident_record:
  schema_version: cli-agent-incident-response-0.1
  incident_id: string
  created_at: string
  updated_at: string | null
  governing_entity_id: string
  status: opened | triaged | preserved | contained | repairing | validated | reported |
memory_gated | monitoring | closed | quarantined | escalated

  classification:
    incident_class: IR-C-AGENT | IR-C-PERMISSION | IR-C-SANDBOX | IR-C-MEMORY | IR-C-CLOUD-
DATA | IR-C-SECRET | IR-C-TOOLCHAIN | IR-C-WITNESS | IR-C-RELEASE | IR-C-CORE | IR-C-
INCIDENT-PROCESS | IR-C-EXTERNAL | IR-C-UNKNOWN | IR-C-REDLINE
    severity: IR-S0 | IR-S1 | IR-S2 | IR-S3 | IR-S4 | IR-S5 | IR-SX
    confidence: low | medium | high | unknown

  affected:
    agent_ids:
      - string
    task_ids:
      - string
    contract_ids:
      - string
    permission_grant_ids:
      - string
    sandbox_ids:
      - string
    memory_gate_refs:
      - string
    witness_chain_refs:
      - string
    release_refs:
      - string
    cloud_context_refs:
      - string
    path_refs:
      - string

  records:
    triage_ref: string | null
    preservation_ref: string | null
    containment_ref: string | null
    repair_ref: string | null
    rollback_ref: string | null
    report_packet_ref: string | null
    memory_gate_ref: string | null
    immunity_candidate_ref: string | null

  boundaries:
    owned_authorized_scope_only: true
    external_action_used: false
    live_counteroperation_used: false
    prohibited_behavior_detected: boolean

  authority:
    c_gate_ref: string | null
    human_gate_ref: string | null
    legal_review_ref: string | null
    security_review_ref: string | null

  witness:
    witness_required: true
    witness_refs:
      - string

  closure:
    closure_decision: no_action | fixed | mitigated | monitored | reported | transferred |
false_positive | unresolved | quarantined | revoked
    closure_reason: string | null
```

```
follow_up_required: boolean
follow_up_refs:
  - string
```

22. Event families

Event families use prefix:

```
cli_agent.incident_response.*
```

Event family	Meaning
cli_agent.incident_response.detected	incident detected
cli_agent.incident_response.triaged	triage completed
cli_agent.incident_response.hold_applied	hold applied
cli_agent.incident_response.freeze_applied	freeze applied
cli_agent.incident_response.preservation_started	preservation started
cli_agent.incident_response.preservation_completed	preservation completed
cli_agent.incident_response.quarantine_applied	quarantine applied
cli_agent.incident_response.containment_applied	containment applied
cli_agent.incident_response.revocation_applied	revocation applied
cli_agent.incident_response.secret_rotation_recommended	secret rotation recommended
cli_agent.incident_response.secret_rotation_completed	owned secret rotation completed
cli_agent.incident_response.repair_task_created	repair task created
cli_agent.incident_response.repair_validated	repair validated
cli_agent.incident_response.rollback_completed	rollback completed
cli_agent.incident_response.report_packet_created	report packet created
cli_agent.incident_response.report_sent	report sent through lawful route
cli_agent.incident_response.memory_gate_completed	incident learning memory-gated
cli_agent.incident_response.immunity_candidate_created	defensive immunity candidate created
cli_agent.incident_response.monitoring_started	monitoring started
cli_agent.incident_response.closed	incident closed

Event family	Meaning
<code>cli_agent.incident_response.redline_detected</code>	red-line detected
<code>cli_agent.incident_response.live_counter_attempt</code>	prohibited live counter-operation attempted

23. Standard reason codes

23.1 Detection and triage codes

```

agent_scope_violation
permission_drift_detected
denied_path_attempt
memory_poisoning_suspected
direct_memory_write_attempt
cloud_data_exposure_suspected
secret_exposure_suspected
toolchain_drift_detected
witness_chain_break
release_surface_error
core_authority_risk
external_hostile_signal
unknown_incident
redline_attempt

```

23.2 Preservation and containment codes

```

preserve_before_repair
evidence_minimized
freeze_affected_path
quarantine_output
revoke_permission
suspend_agent
rotate_owned_secret
block_owned_channel
release_freeze
memory_gate_freeze
core_freeze

```

23.3 Repair and validation codes

```

repair_in_sandbox
patch_validated
tests_passed
tests_failed
rollback_validated
reentry_allowed
reentry_limited
continue_monitoring

```

23.4 Report and handoff codes

```
provider_report_prepared
legal_review_required
security_review_required
maintainer_report_prepared
no_external_action
lawful_route_only
```

23.5 Red-line codes

```
hackback_risk
live_counteroperation_attempt
malware_behavior_detected
credential_theft_risk
evasion_risk
unauthorized_scanning_risk
retaliation_language_detected
evidence_destruction_risk
```

24. Validation workflow

```
parse incident record
-> validate scope is owned/authorized/delegated
-> classify incident class
-> classify severity
-> check red-line presence
-> determine preservation need
-> freeze/contain if needed
-> preserve minimal evidence
-> create repair task if needed
-> validate repair in sandbox
-> apply through controlled gate
-> create report packet if needed
-> process incident learning through memory gate
-> create immunity candidate if justified
-> monitor
-> close or continue quarantine
```

25. Semantic validation rules

25.1 Owned/authorized scope rule

If the incident response would require action on a system not owned or explicitly authorized, the action must stop and route to lawful report/handoff only.

25.2 No counter-operation rule

Any proposed response that affects a live external source must be rejected unless it is a lawful defensive action within owned/authorized scope, such as blocking, disconnecting, or reporting.

25.3 Preserve-before-repair rule

If evidence may be needed, repair must not destroy it before preservation unless immediate containment requires it.

25.4 Secret minimization rule

Reports and witness records must not embed raw secrets.

25.5 Cloud exposure rule

If prohibited material entered cloud context, incident severity increases and human review is required.

25.6 Memory gate rule

Incident learning cannot directly become c memory or immunity. It must pass through memory gate.

25.7 Public statement rule

Public statements about incidents must be fact/interpretation/hypothesis separated and reviewed before publication.

26. Failure mapping

Failure	Required default
unknown scope	hold
action targets unauthorized external system	deny_and_handoff
live counter-operation requested	deny_and_quarantine
secret exposure suspected	freeze_and_escalate
cloud exposure suspected	freeze_and_review
evidence preservation skipped improperly	incident_process_review
repair task lacks sandbox	hold
repair task lacks rollback	hold

Failure	Required default
witness chain broken	freeze_and_revalidate
memory poisoning suspected	memory_gate_quarantine
core authority risk	core_freeze_human_gate
release/public error	release_freeze_human_gate
red-line behavior detected	quarantine_revoke_human_review

27. Conformance levels

Level	Meaning
IRP-0	no incident response discipline
IRP-1	manual triage and hold
IRP-2	structured triage + freeze/quarantine
IRP-3	preservation + sandbox repair + witness
IRP-4	memory/release/cloud/core incident handling + lawful reports
IRP-5	high assurance: drills, recovery points, legal/security handoff, immunity update linkage, red-line veto
IRP-X	non-conformant / retaliation / evidence destruction / red-line mishandling

28. Mandatory conformance gates

Gate	Name	Blocking failure
G0	Scope classification	owned/authorized scope not established
G1	Triage	incident not classified
G2	Preservation	evidence repair conflict unresolved
G3	Freeze/containment	harmful path cannot be stopped
G4	Secret handling	raw secrets embedded in reports/witness
G5	Cloud handling	cloud exposure ignored

Gate	Name	Blocking failure
G6	Sandbox repair	repair made directly in protected state
G7	Validation	repair applied without validation
G8	Witness	material incident actions unwitnessed
G9	Memory gate	incident learning bypasses memory gate
G10	No retaliation	live counter-operation allowed

29. Red-line failures

A system MUST be classified as IRP-X if:

1. incident response includes hack-back;
2. incident response includes live external counter-operation;
3. incident response includes malware behavior;
4. incident response includes credential theft;
5. incident response includes unauthorized scanning;
6. incident response destroys evidence without necessity;
7. incident response exports secrets to cloud;
8. incident response silently rewrites witness history;
9. agent self-approves incident repair;
10. incident learning enters memory directly;
11. public accusation is generated without review;
12. red-line incident is treated as ordinary task failure.

30. Examples

30.1 Denied path incident

```
cli_agent_incident_record:
  schema_version: cli-agent-incident-response-0.1
  incident_id: ir-20260516-denied-path-001
  created_at: "2026-05-16T23:40:00Z"
  updated_at: null
  governing_entity_id: ester
  status: contained
```

```

classification:
  incident_class: IR-C-SANDBOX
  severity: IR-S2
  confidence: high

affected:
  agent_ids:
    - codex-executor-01
  task_ids:
    - task-schema-patch-001
  contract_ids:
    - catc-20260516-130000-schema-patch
  permission_grant_ids:
    - grant-schema-patch-001
  sandbox_ids:
    - sb-docs-patch-001
  memory_gate_refs: []
  witness_chain_refs:
    - chain-task-schema-patch-001
  release_refs: []
  cloud_context_refs: []
  path_refs:
    - denied_path_ref_redacted

records:
  triage_ref: triage-denied-path-001
  preservation_ref: null
  containment_ref: containment-denied-path-001
  repair_ref: null
  rollback_ref: rb-docs-patch-001
  report_packet_ref: null
  memory_gate_ref: null
  immunity_candidate_ref: null

boundaries:
  owned_authorized_scope_only: true
  external_action_used: false
  live_counteroperation_used: false
  prohibited_behavior_detected: false

authority:
  c_gate_ref: cgate-denied-path-001
  human_gate_ref: null
  legal_review_ref: null
  security_review_ref: null

witness:
  witness_required: true
  witness_refs:
    - we-denied-path-001
    - we-containment-001

closure:
  closure_decision: monitored
  closure_reason: Output quarantined and task held pending review.
  follow_up_required: true
  follow_up_refs:
    - review-denied-path-001

```

30.2 Secret exposure incident

```

cli_agent_incident_triage_record:
  schema_version: cli-agent-incident-response-0.1
  triage_id: triage-secret-001
  incident_id: ir-20260516-secret-001
  created_at: "2026-05-16T23:50:00Z"
  governing_entity_id: liya
  detected_by: sentinel

```

```

detected_by_ref: local-sentinel-01

classification:
  incident_class: IR-C-SECRET
  severity: IR-S4
  confidence: medium
  redline_suspected: false

affected_scope:
  agent_ids:
    - codex-executor-01
  task_ids:
    - task-config-review-001
  contract_ids:
    - catc-config-review-001
  permission_grant_ids:
    - grant-config-review-001
  sandbox_ids:
    - sb-config-review-001
  memory_gate_refs: []
  witness_chain_refs:
    - chain-config-review-001
  paths:
    - secret_location_ref_redacted
  cloud_context_refs:
    - cloud-context-ref-001

immediate_actions:
  hold_required: true
  freeze_required: true
  preserve_required: true
  quarantine_required: true
  revoke_required: true
  human_gate_required: true
  legal_review_required: false

prohibited_actions:
  live_counteroperation: true
  external_exploitation: true
  credential_theft: true
  evidence_destruction: true

witness:
  witness_required: true
  witness_event_ref: we-secret-triage-001

```

Required outcome:

```

freeze task
quarantine cloud output
preserve minimal evidence without raw secret
rotate/revoke owned secret if needed
human review
witness

```

30.3 External hostile signal, no counter-operation

```

cli_agent_incident_record:
  schema_version: cli-agent-incident-response-0.1
  incident_id: ir-20260517-external-signal-001
  created_at: "2026-05-17T00:05:00Z"
  updated_at: null
  governing_entity_id: ester
  status: memory_gated

classification:

```

```

incident_class: IR-C-EXTERNAL
severity: IR-S3
confidence: medium

affected:
  agent_ids: []
  task_ids: []
  contract_ids: []
  permission_grant_ids: []
  sandbox_ids:
    - sb-external-signal-fixture-001
  memory_gate_refs:
    - mg-external-signal-001
  witness_chain_refs:
    - chain-external-signal-001
  release_refs: []
  cloud_context_refs: []
  path_refs: []

records:
  triage_ref: triage-external-signal-001
  preservation_ref: preserve-external-signal-001
  containment_ref: containment-external-signal-001
  repair_ref: null
  rollback_ref: null
  report_packet_ref: provider-report-draft-001
  memory_gate_ref: mg-external-signal-001
  immunity_candidate_ref: imm-external-signal-001

boundaries:
  owned_authorized_scope_only: true
  external_action_used: false
  live_counteroperation_used: false
  prohibited_behavior_detected: false

authority:
  c_gate_ref: cgate-external-signal-001
  human_gate_ref: human-review-external-signal-001
  legal_review_ref: null
  security_review_ref: security-review-external-signal-001

witness:
  witness_required: true
  witness_refs:
    - we-external-signal-detected-001
    - we-no-counteroperation-001

closure:
  closure_decision: monitored
  closure_reason: Hostile signal converted to internal defensive fixture and quarantine
  rule: No external action taken.
  follow_up_required: true
  follow_up_refs:
    - monitor-external-signal-001

```

31. Implementation notes

31.1 Split preservation and repair

When possible, preservation and repair should use separate task contracts and possibly separate agents.

31.2 Do not overcollect

Overcollection creates privacy and legal risk. Preserve enough, not everything.

31.3 Treat cloud as leaky by default

If a cloud agent saw sensitive material, assume it may not be retractable. Stop further exposure and review.

31.4 Keep incident language factual

Separate:

```
facts
interpretation
hypothesis
actions taken
requested action
```

31.5 No heroic automation

Fast containment is useful. Fast revenge is not incident response.

31.6 Human fatigue rule

High-risk incident decisions should not be made by an exhausted human anchor except for immediate containment.

31.7 Incident learning is not automatic memory

Even useful incident conclusions must pass through memory gate.

32. Open issues

ID	Issue	Required action
OI-001	JSON Schema extraction	Extract incident objects to <code>.schema.json</code> .
OI-002	Incident severity scoring	Define numeric criteria for IR-S0...IR-SX.
OI-003	Secret rotation companion	Link to future Secrets and Cloud Data Policy.
OI-004	Provider report templates	Define provider-specific report formats.
OI-005	Legal handoff profile	Define counsel/regulator packet boundary.

ID	Issue	Required action
OI-006	Incident drills	Define conformance drills.
OI-007	Cloud exposure handling	Expand cloud exposure response matrix.
OI-008	Release incident binding	Link to future Release/Public Surface Profile.
OI-009	Memory poisoning incident tests	Link to Defensive Emulation and Memory Gate profiles.
OI-010	Repo placement	Decide final GitHub path and package index integration.

33. Closing rule

Incident response is where discipline matters most.

A c with executable agents must be able to defend itself without becoming an attacker.

Final rule:

```
Contain what is yours.
Report what is external.
Repair what is broken.
Do not retaliate.
```